

XP Cyber Range: A Sense of Security [NG] - Capstone Project

Security Assessment for DASWebs Inc.

Ryan Verrot

Pikes Peak State College

CNG 2059 1N1: Enterprise Security

Professor [REDACTED]

2026-05-10 23:59

XP Cyber Range: A Sense of Security [NG] - Capstone Project

Table of Contents

1. Introduction

- 1.1. Purpose and Scope
- 1.2. Assessment Methodology
- 1.3. Network Architecture Overview

2. Current Network Security Posture Assessment (Task 1)

- 2.1. Network Segmentation
- 2.2. Security Appliance Implementation
- 2.3. Network Protocols and Communications
- 2.4. Endpoint Security
- 2.5. Vulnerability Summary

3. Risk Assessment (Task 2)

- 3.1. Risk Scoring Methodology
- 3.2. Prioritized Risk Findings
- 3.3. Attack Path Analysis

4. Recommendations (Task 3)

- 4.1. Updated Network Architecture
- 4.2. Recommended Security Tools
- 4.3. Device-Specific Configurations
- 4.4. Attack Surface Reduction
- 4.5. Implementation Roadmap

5. Conclusion

6. References

7. Appendix

XP Cyber Range: A Sense of Security [NG] - Capstone Project

1. Introduction

1.1. Purpose and Scope

This report documents the findings, risk assessment, and recommendations resulting from a security assessment of the DASWebs Inc. network infrastructure conducted as part of the CNG 2059: Enterprise Security - Capstone Project. The assessment was performed within the XP Cyber Range: A Sense of Security [NG] challenge environment, which replicates the production network architecture of the fictional DASWebs Inc. organization.

The objective of this assessment is to evaluate the current cybersecurity posture of the DASWebs Inc. network, identify weaknesses and vulnerabilities across major network components, and provide prioritized, implementable recommendations to improve the organization's security posture. The report is written in a professional format and is intended to clearly communicate the assessment findings, risk priorities, and recommended security improvements.

The scope of this assessment encompasses the following network segments and systems:

- **Production Subnet (172.16.10.0/24):**
 - Prod-Web (172.16.10.7)
- **Development Subnet (172.16.20.0/24):**
 - Database (172.16.20.4)
 - Dev-Web (172.16.20.11)
- **Internal Subnet (172.16.30.0/24):**
 - Domain Controller (172.16.30.5)
 - Mail (172.16.30.21)
 - Fileshare (172.16.30.32)
 - Backup (172.16.30.79)

- Security-Desk (172.16.30.6)
 - Workstation-Desk (172.16.30.101)
 - **Network Perimeter:**
 - Firewall (172.16.10.2, 172.16.20.2, 172.16.30.2, 172.31.2.2) - pfSense 2.5.0
- Firewall with interfaces on all subnets.

These systems and network segments were assessed with a focus on network segmentation, security appliance implementation, protocols and communications, and endpoint security, in alignment with the project requirements.

1.2. Assessment Methodology

The assessment methodology included automated vulnerability scanning using Nmap 7.94SVN, host-based security data collection scripts executed on selected systems, network traffic capture and analysis, firewall configuration review, and manual analysis of the collected security data. Most assessment activities were conducted from the Security-Desk workstation (172.16.30.6) using the provided authorized credentials, with additional local script execution performed on Prod-Web (172.16.10.7), Database (172.16.20.4), Dev-Web (172.16.20.11), and Domain Controller (172.16.30.5).

Table 1 - Assessment Tools and Techniques

Table 1 summarizes the primary tools and techniques used during the assessment, along with their target scope and purpose.

Assessment Phase:	Tool or Technique:	Target Scope:	Purpose:
Vulnerability Scanning	Nmap 7.94SVN with NSE scripts (vulners, vulscan, smb-vuln-ms17-010, http-enum)	All in-scope hosts across 172.16.10.0/24, 172.16.20.0/24, and 172.16.30.0/24	Identify open ports, service versions, and relevant known vulnerabilities or CVEs.
Network Mapping	Nmap host discovery with traceroute (-sn -PE -PP -PS -PA -PU -PY -PO --traceroute)	All in-scope hosts across 172.16.10.0/24, 172.16.20.0/24, and 172.16.30.0/24	Identify live hosts, map basic network topology, and observe routing behavior.

Service Enumeration	Nmap OS detection and service version scanning (-O -sV)	All in-scope hosts	Identify operating systems and service versions to support vulnerability correlation.
Full Port Scan	Nmap all-port TCP scan (-p- -T4)	All in-scope hosts	Identify services running on non-standard ports not found during initial scanning.
Traffic Capture	tcpdump (10,000 packets)	Security-Desk network interfaces	Capture live network traffic to assess protocol usage, identify cleartext communications, and observe network behavior.
Firewall Configuration Review	Manual analysis of rc.firewall configuration script	Firewall appliance (pfSense 2.5.0)	Review firewall rule logic, segmentation behavior, and overall security posture.
Host-Level Data Collection	Custom security scripts (linux_security_script.sh, windows_security_script.ps1)	Prod-Web, Dev-Web, Database, and Domain Controller	Collect host configuration data, installed services, user account information, and local security settings.
Firewall Web UI Review	Manual inspection of pfSense web management interface	Firewall appliance	Document firewall configuration, interface assignments, and NAT/routing rules

A detailed timeline of assessment activities is provided in Appendix A. Supporting screenshot evidence documenting each phase of data collection is included in Appendix B. Additional supplemental assessment artifacts, including security scripts and raw scan output files, are provided in Appendix C through a read-only OneDrive folder.

Limitations

- Scope Deviation:** The 172.31.2.0/24 subnet was inadvertently included in the network mapping and service enumeration scans. Upon review of the provided DASWebs Inc.

network diagram, this subnet represents the public network containing the ISP gateway (172.31.2.1) and the External MSP (172.31.2.5), which are both designated as out-of-scope. Results for hosts on this subnet have been excluded from the assessment findings.

- **Full Port Scan Cancellation:** The all-port TCP scan (-p-) was terminated early due to time constraints with the environment caused by the inadvertent inclusion of the out-of-scope 172.31.2.0/24 subnet. However, all 12 in-scope devices completed scanning before the cancellation occurred.
- **Firewall Configuration Inference:** The active `firewall_type` value in the pfSense `/etc/rc.conf` file was not directly verified through command-line inspection. As a result, conclusions about firewall behavior are based on observed evidence rather than direct confirmation of a specific operating mode. The assessment found that the firewall appeared to permit broad inter-subnet communication, based on configuration script analysis, cross-subnet scan behavior, and live traffic capture analysis.

1.3. Network Architecture Overview

The current DASWebs Inc. network environment consists of three internal subnets connected through a single pfSense 2.5.0 firewall appliance with interfaces on each segment and a WAN connection to the public internet. This section describes the current state of architecture used for the assessment and should be distinguished from the recommended future network design presented later in the report. The images and host inventory below summarize the environment documentation provided for the lab:

Figure 1 - DASWebs Inc. Network Diagram:

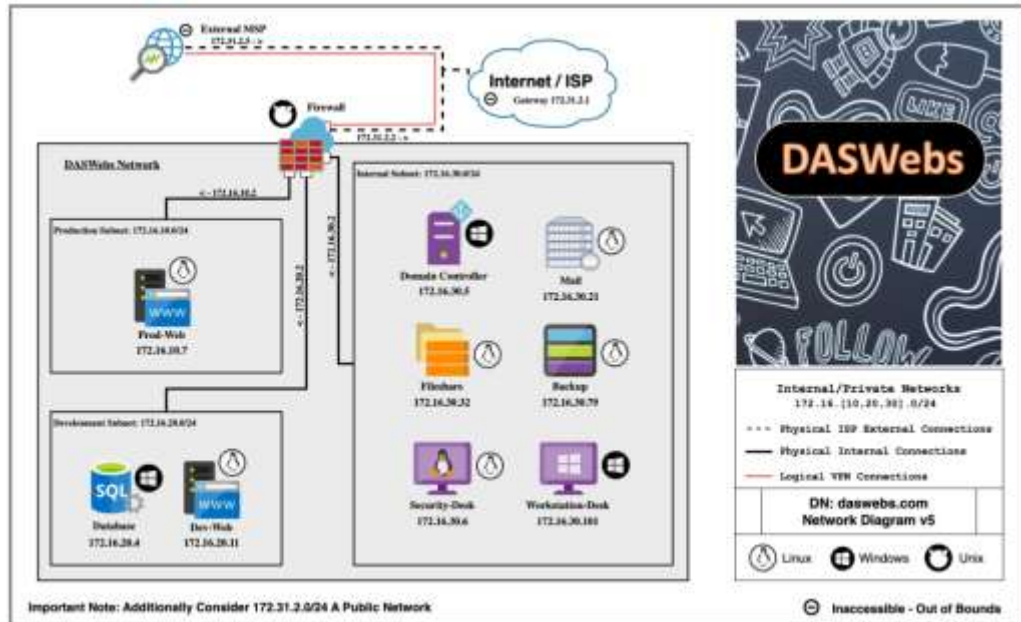


Table 2 - DASWebs Inc. Host Inventory:

Hostname:	IP Address:	Operating System/Version:	User Account:	Description:
Ryan-Legion	[REDACTED]	Windows 11 Pro 25H2	[REDACTED]	Personal Windows 11 Pro laptop/workstation utilized to access the XP Cyber Range: A Sense of Security [NG] lab environment required to complete the CNG 2059 Capstone Project.
Prod-Web	172.16.10.7	Alma Linux 9.3	playerone	Production web server in the XP Cyber Range: A Sense of Security [NG] lab environment.
Dev-Web	172.16.20.11	Ubuntu 20.04.2 LTS	playerone	Development web server in the XP Cyber Range: A Sense of Security [NG] lab environment.
Database	172.16.20.4	Windows Server 2012 R2 Standard	playerone	Backend database from the XP Cyber Range: A Sense of Security [NG] lab environment.
Domain Controller	172.16.30.5	Windows Server 2012 R2 Standard	playerone	Active Directory, DNS, and authentication server in the XP Cyber Range: A Sense of Security [NG] lab environment.
Firewall	172.16.10.2; 172.16.20.2; 172.16.30.2; 172.31.2.2	pfSense 2.5.0	playerone	Firewall and network perimeter device for the XP Cyber Range: A Sense of Security [NG] lab environment.

Mail	172.16.30.21	Alma Linux 9.6	playerone	Email provider for the XP Cyber Range: A Sense of Security [NG] lab environment.
Fileshare	172.16.30.32	Open Media Vault 7.1.1-1	playerone	File sharing server in the XP Cyber Range: A Sense of Security [NG] lab environment.
Backup	172.16.30.79	Debian GNU/Linux 9	playerone	Backup server in the XP Cyber Range: A Sense of Security [NG] lab environment.
Security-Desk	172.16.30.6	Linux (Kali)	playerone	Security workstation in the XP Cyber Range: A Sense of Security [NG] lab environment, used to conduct the assessment.
Workstation-Desk	172.16.30.101	Windows 10 Pro 1809	playerone	End-user workstation from the XP Cyber Range: A Sense of Security [NG] lab environment.

An external Managed Service Provider (MSP) at 172.31.2.5 connects to the firewall through a logical VPN tunnel. Per the lab environment documentation, both the ISP gateway (172.31.2.1) and the external MSP are treated as out-of-scope for assessment findings.

The following sections evaluate the current environment, prioritize the identified risks, and present recommendations designed to improve segmentation, strengthen monitoring and access control, and reduce the attack surface of the DASWebs Inc. network.

2. DASWebs Inc. Network Security Posture Assessment

The following assessment evaluates the DASWebs Inc. network across the four security areas specified in the CNG 2059: Enterprise Security Capstone Project requirements including network segmentation, security appliance implementation, network protocols and communications, and endpoint security. Findings are supported by evidence collected through vulnerability scanning, traffic capture analysis, firewall configuration review, and host-level data collection.

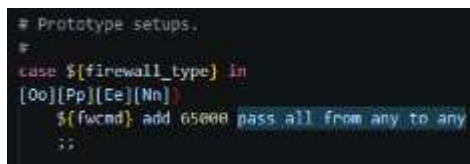
2.1. Network Segmentation

The DASWebs Inc. network is divided into three subnets consisting of Production, Development, and Internal. Each subnet is connected through a dedicated interface on the pfSense firewall. Although

this architecture appears segmented at a high level, assessment evidence indicates that effective traffic filtering between subnets is not being enforced. Three independent evidence sources support this conclusion:

1. **Firewall Configuration Analysis:** The rc.firewall script on the pfSense appliance contains an open profile consisting of a single “pass all from any to any” rule. Observed network behavior during scanning is consistent with this profile being active.

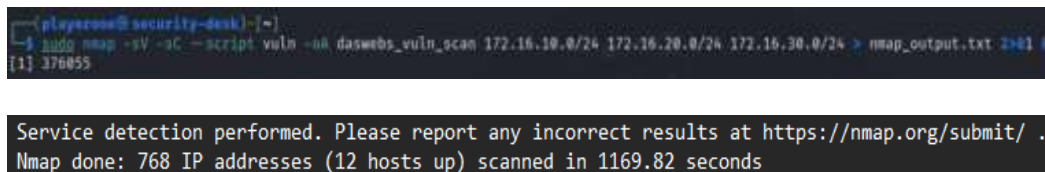
Figure 2 - Firewall rc.firewall Configuration:



```
# Prototype setups.
#
case ${firewall_type} in
[0o][Pp][Ee][Nn])
    ${fwcmd} add 65000 pass all from any to any
;;
```

2. **Cross-Subnet Scan Behavior:** During vulnerability scanning, Security-Desk (Internal Subnet) successfully scanned all ports on all hosts across the Production and Development Subnets without any connections being blocked or rate-limited.

Figure 3 - Nmap Vulnerability Scan:

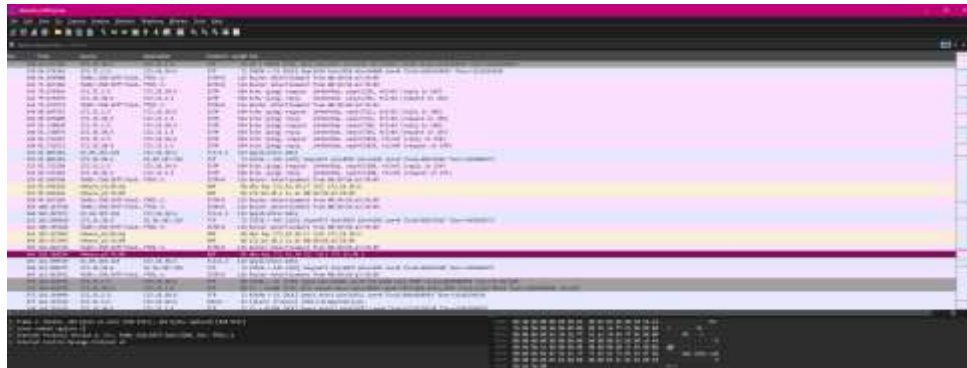


```
playerone@security-desk:~$ sudo nmap -sV -oC --script vuln -oR daswebs_vuln_scan 172.16.10.0/24 172.16.20.0/24 172.16.30.0/24 -o nmap_output.txt 2>&1 &
[1] 376055

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 768 IP addresses (12 hosts up) scanned in 1169.82 seconds
```

3. **Live Traffic Capture:** Analysis of 10,000 packets captured during tcpdump showed 4,640 TCP SYN probes traversing from the Internal Subnet toward Production and Development without being dropped. The firewall also responded to probes targeting non-existent hosts with 1,356 ICMP Host Unreachable messages, behavior more consistent with routing than restrictive inter-subnet filtering (Scarfone & Hoffman, 2009).

Figure 4 - WireShark Tcpdump Analysis:



The Internal Subnet compounds this issue by placing seven hosts on a single broadcast domain, including the Domain Controller, Fileshare, Mail server, Backup server, Security-Desk, and a user workstation. Because these systems share the same subnet without effective internal separation, compromise of one host could make lateral movement to neighboring systems significantly easier.

Additionally, the Production Subnet does not function as a true demilitarized zone (DMZ). Prod-Web appears able to communicate with internal systems without sufficient restriction, which means a compromise of the WordPress host could increase the risk of lateral movement toward higher-value internal assets such as the Domain Controller or Fileshare.

2.2. Security Appliance Implementation

The pfSense 2.5.0 firewall is the only dedicated security appliance on the DASWebs Inc. network. It is simultaneously serving as the inter-subnet router, internet gateway, DNS resolver, VPN termination point, and web management host. This creates a significant single point of failure for both connectivity and security enforcement.

As documented in Section 2.1, the firewall does not appear to be enforcing effective inter-subnet access controls. NIST SP 800-41 Rev. 1 recommends a deny-by-default, permit-by-exception firewall policy with logging configured to support monitoring and review (**Scarfone & Hoffman, 2009**). The DASWebs Inc. firewall does not reflect those practices.

Figure 5 - Firewall Web UI WAN Rules:

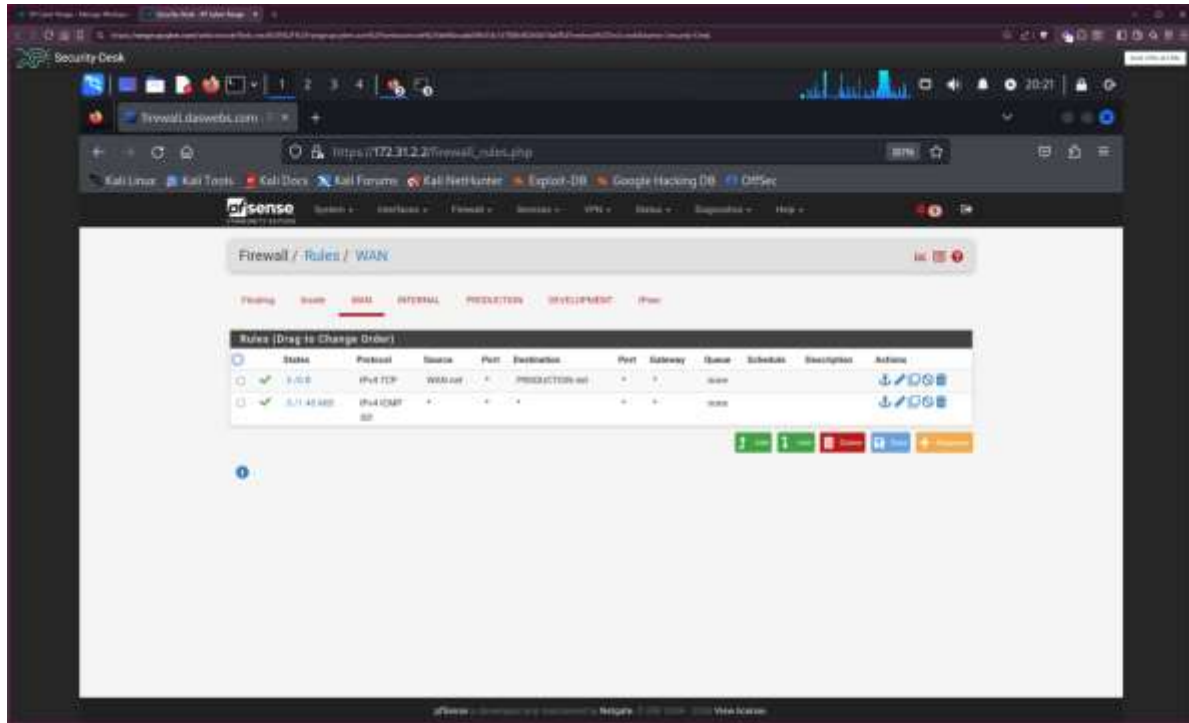


Figure 6 - Firewall Web UI Internal Subnet Rules:

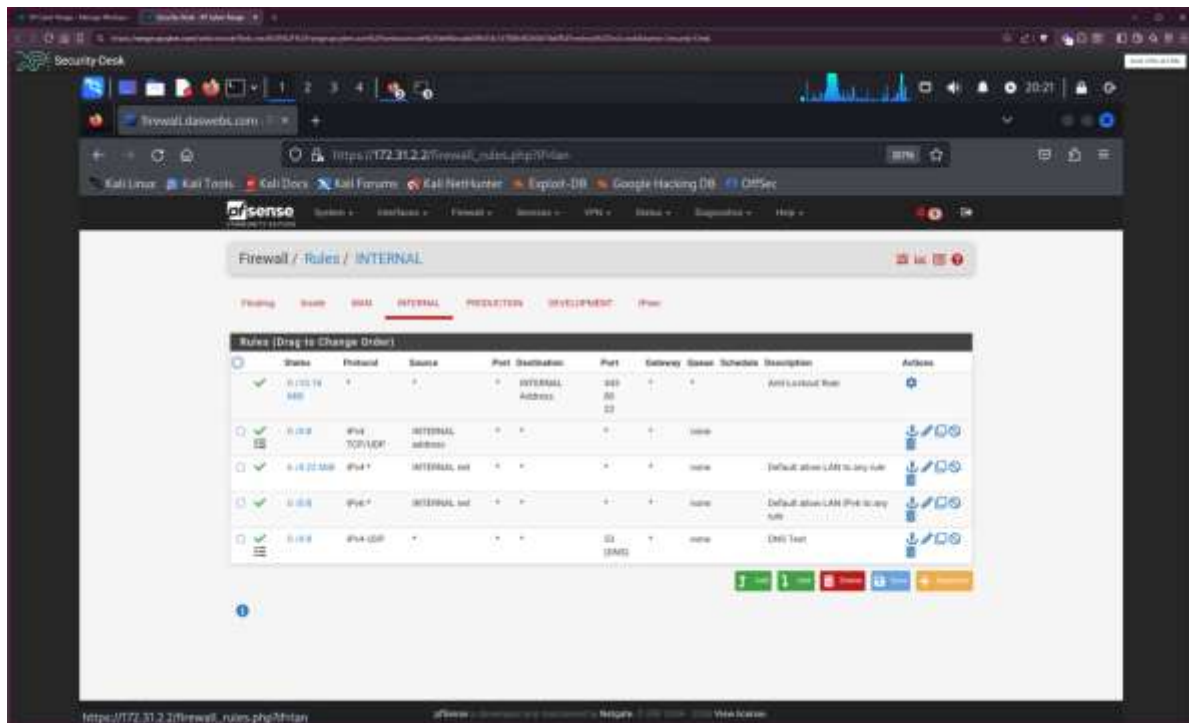


Figure 7 - Firewall Web UI Production Rules:

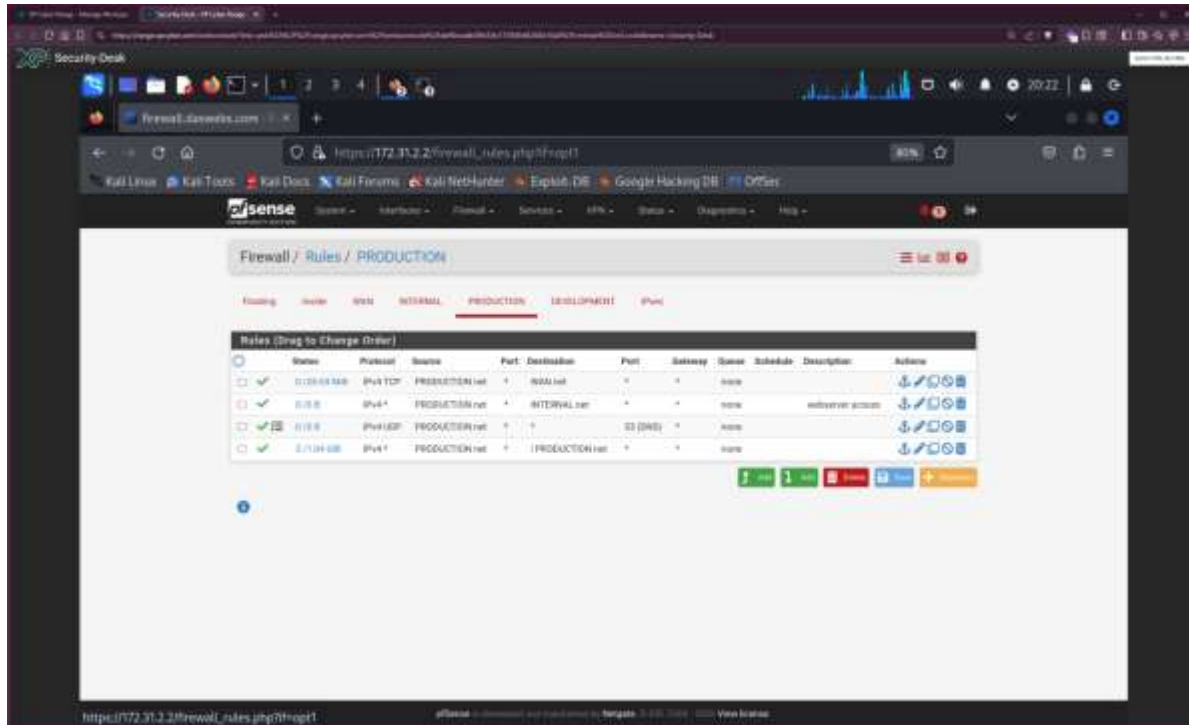
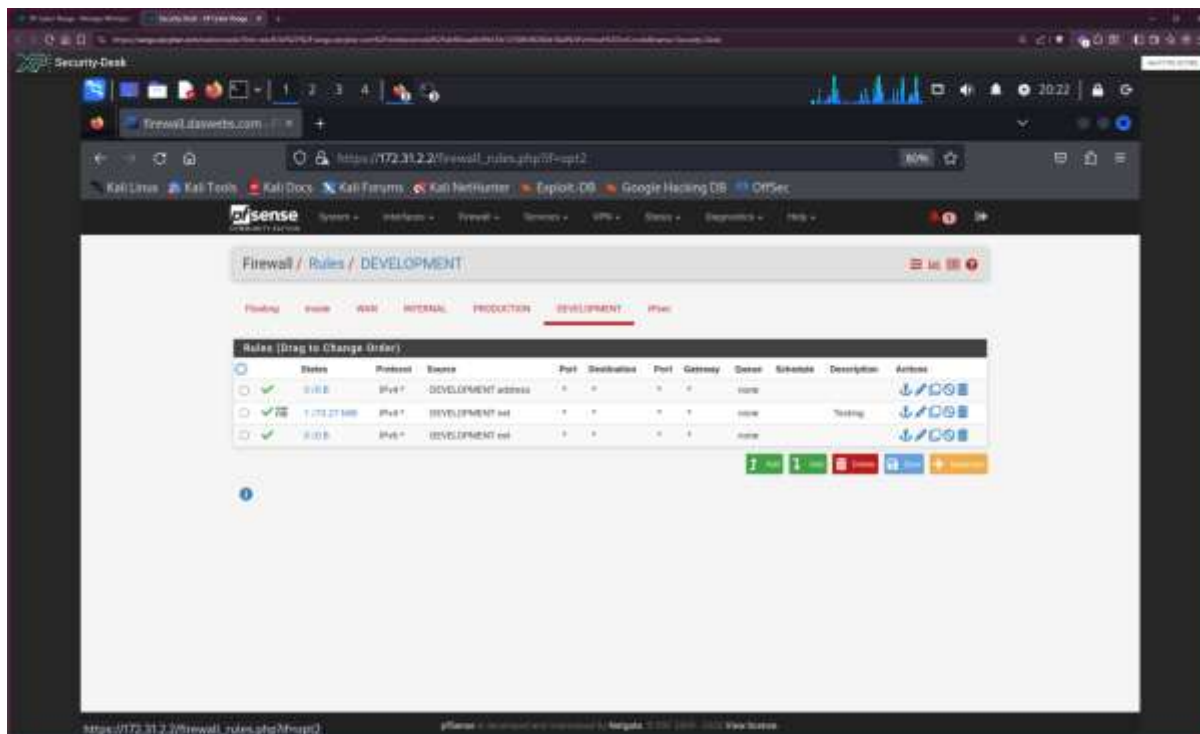


Figure 8 - Firewall Web UI Development Rules:



The pfSense 2.5.0 release is outdated and no longer represents a current, fully supported firewall platform for this environment. The appliance also exposes an older OpenSSH service version that increases the need for careful patch verification and configuration review. Rather than relying on a large undifferentiated CVE count, this assessment treats the outdated management service as an elevated risk requiring remediation.

Traffic capture also showed repeated SSH activity between the External MSP (172.31.2.5) and the Security-Desk endpoint over the VPN connection at approximately 60-second intervals. Based on the evidence available during the assessment, no indication of multi-factor authentication, session logging, or time-based access restriction was observed. NIST SP 800-53 Rev. 5 control AC-17 requires organizations to authorize, monitor, and control remote access methods (**Joint Task Force, 2020**).

The following security controls were observed to be absent from the DASWebs Inc. network:

Table 3 - DASWebs Inc. Missing Security Controls:

Missing Control:	NIST 800-53 Rev. 5 Control:	Impact:
Intrusion Detection/Prevention	SI-4 (System Monitoring)	No network-based detection of exploit attempts or abnormal traffic
SIEM	AU-6 (Audit Record Review, Analysis, and Reporting)	No centralized logging, correlation, or alerting
Web Application Firewall	SC-7 (Boundary Protection)	No application-layer protection for the public WordPress site
Endpoint Detection and Response	SI-3 (Malicious Code Protection)	No centralized host-based detection or response capability
Vulnerability Management	RA-5 (Vulnerability Monitoring and Scanning)	No scheduled scanning, remediation tracking, or patch verification

2.3. Network Protocols and Communications

Multiple insecure or weakly protected protocols are in active use across the DASWebs Inc. network, and encrypted alternatives are not consistently enforced. NIST SP 800-123 recommends

disabling unnecessary services and using more secure alternatives for protocols that may transmit credentials or other sensitive data (Souppaya & Scarfone, 2008).

Figure 9 - DASWebs Inc. Nmap Port Scan:

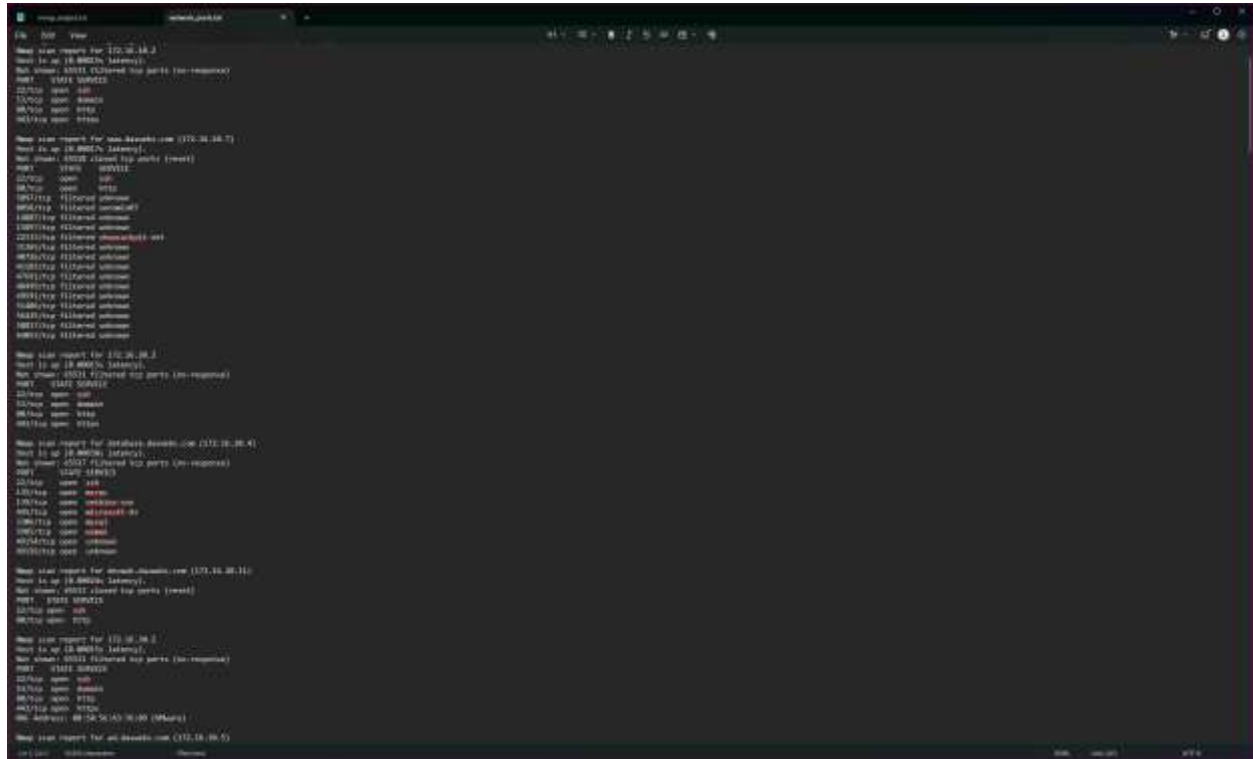


Table 4 - Insecure Protocols Identified:

Protocol or Service:	Port:	Affected Host(s):	Security Risk:
FTP (cleartext)	21	Backup	Credentials and files transmitted in plaintext
SMTP (cleartext)	25	Mail	Email transmitted without encryption
HTTP (cleartext)	80	6 Hosts	Login credentials in plaintext; WordPress admin exposed
POP3 (cleartext)	110	Mail	Email retrieval credentials in plaintext
IMAP (cleartext)	143	Mail	Email retrieval credentials in plaintext
NetBIOS/SMBv1	139	4 Hosts	Legacy protocol with critical known vulnerabilities
LDAP (cleartext)	389	Domain Controller	AD authentication in plaintext

NFS	2049	Fileshare	No inherent encryption or strong authentication
LLMNR	5355	Fileshare	Vulnerable to poisoning for credential capture
WinRM (HTTP)	5985	3 Windows hosts	Remote PowerShell over unencrypted HTTP

Additional findings from traffic capture and scanning include:

- HTTP TRACE is enabled on Prod-Web, which can facilitate Cross-Site Tracing attacks.
- NetBIOS Browser Announcements from Domain Controller and Backup broadcasting host roles (“Domain Controller, Time Source” and “Local Master Browser, DFS server”) to the subnet broadcast address.
- TLS v1.2 was observed in use for external communications. Although TLS v1.2 remains supported in many environments, TLS v1.3 is the stronger modern standard and should be preferred where supported.

2.4. Endpoint Security

During the endpoint security assessment, five of the eleven hosts and the firewall were observed to be running end-of-life operating systems that no longer receive regular security updates, including:

Table 5 - End-of-Life Operating Systems Identified:

Host:	Operating System:	End-of-Life Date:
Firewall	pfSense 2.5.0 (FreeBSD-based)	EOL (current: pfSense Plus 24.11)
Database	Windows Server 2012 R2	October 2023
Domain Controller	Windows Server 2012 R2	October 2023
Workstation-Desk	Windows 10 Pro 1809	November 2020
Backup	Debian 9 "Stretch"	June 2022

No endpoint protection agents, antivirus services, or host-based intrusion detection capabilities were identified on the assessed DASWebs Inc. hosts. Vulnerability scanning was able to run across systems without signs of host-based protection interfering or generating alerts. NIST SP 800-53 Rev. 5 control SI-3 requires malicious code protection at system entry and exit points (**Joint Task Force, 2020**).

Additionally, multiple administrative interfaces appear to be exposed without adequate restriction, including the WordPress login page (/wp-login.php) on Prod-Web, an unauthenticated JMX Console on Fileshare, the MediaWiki /setup/ directory on Backup, and WinRM (port 5985) on all three Windows hosts. These exposures increase the attack surface and provide potential entry points for unauthorized access or abuse. Public exploit and offensive tooling also exist for older OpenSSH versions associated with CVE-2018-15473, which affects the Domain Controller, Database, and Workstation-Desk systems.

2.5. Vulnerability Summary

Vulnerability scanning and host-level review identified more than 664 individual vulnerability or exposure entries across the assessed hosts. Table 6 consolidates the most significant findings into a prioritized summary for further analysis.

Table 6 - Vulnerability Summary:

#:	Finding:	Severity:	Affected Host(s):	Key CVEs/Basis:
1	EternalBlue - Confirmed Vulnerable	CRITICAL	Domain Controller	CVE-2017-0143
2	SambaCry - RCE via Samba 4.6.2	CRITICAL	Fileshare	CVE-2017-7494
3	Legacy file-sharing exposure and weak service configuration	CRITICAL	Fileshare	Misconfiguration/Samba-related exposure
4	JMX Console - No Authentication	CRITICAL	Fileshare	Misconfiguration
5	Firewall not enforcing effective inter-	CRITICAL	Firewall	Misconfiguration

	subnet access controls			
6	End-of-Life Operating Systems	CRITICAL	5 hosts + Firewall	System
7	Outdated OpenSSH services requiring verification and remediation	HIGH	Multiple hosts	CVE-2023-38408
8	Outdated Apache httpd services with multiple known vulnerabilities	HIGH	Backup, Dev-Web, Prod-Web, Mail	Multiple Apache-related exposures requiring version-specific validation
9	regresSHion - OpenSSH RCE	HIGH	Prod-Web	CVE-2024-6387
10	OpenSSH 7.1 User Enumeration	HIGH	Domain Controller, Database, Workstation-Desk	CVE-2018-15473
11	WinRM Exposed on Critical Hosts	HIGH	Domain Controller, Database, Workstation-Desk	Misconfiguration
12	LLMNR Enabled	HIGH	Fileshare	Misconfiguration
13	Cleartext Protocols	HIGH	Mail, Backup, Domain Controller, +5 others	Misconfiguration
14	Slowloris DoS - Likely Vulnerable	MEDIUM	Firewall, Dev-Web	CVE-2007-6750
15	Additional protocol and service exposures (HTTP TRACE, broadcast leakage, and related weaknesses)	MEDIUM	Various	Various/Misconfiguration

EternalBlue (CVE-2017-0143) on the Domain Controller is the highest-priority finding. It was identified as vulnerable through active testing with the Nmap smb-vuln-ms17-010 script, is included in

Table 7 - Likelihood and Impact Scales:

Score:	Likelihood Definition:	Impact Definition:
5 - Very High	Confirmed vulnerable by active scan or strong version-based evidence. Publicly available exploitation tools exist. The vulnerability is actively exploited in the wild or well documented, and there are no meaningful compensating controls.	Complete organizational compromise or domain takeover. Potential exposure of highly sensitive or organization-wide data. Extended operational disruption or shutdown.
4 - High	Public exploit code available. Version-confirmed vulnerable. Minimal compensating controls.	Critical system compromised. Significant data breach. Major service disruption.
3 - Moderate	CVE exists with known proof-of-concept. Exploitation requires specific conditions.	Single system compromised. Limited data exposure. Partial service disruption.
2 - Low	Exploitation requires local access, authentication, or unusual configuration.	Information disclosure with limited sensitivity. Minor system impact.
1 - Very Low	Theoretical vulnerability. No known exploit. Highly specific preconditions.	Negligible impact. No sensitive data exposure. No operational effect.

Table 8 - Risk Level Determination Matrix:

	Impact: Very Low (1)	Impact: Low (2)	Impact: Moderate (3)	Impact: High (4)	Impact: Very High (5)
Likelihood: Very High (5)	5	10	15	20	25
Likelihood: High (4)	4	8	12	16	20
Likelihood: Moderate (3)	3	6	9	12	15
Likelihood: Low (2)	2	4	6	8	10
Likelihood: Very Low (1)	1	2	3	4	5

Based on the Determination Matrix value, the Risk Levels are defined as the following:

- **Very High (20-25):** Corrective actions recommended immediately.
- **High (12-16):** Corrective actions recommended within 30 days.

- **Moderate (5-10):** Corrective actions recommended within 60-90 days.
- **Low (1-4):** Accept risk or correct during scheduled maintenance.

3.2. Prioritized Risk Findings

Risk #1 - EternalBlue (MS17-010) on Domain Controller:

CVE-2017-0143 (CVSS 9.8). Confirmed vulnerable by active Nmap testing. Listed in CISA's Known Exploited Vulnerabilities Catalog (**CISA, n.d.-a**). Metasploit module provides point-and-click exploitation requiring zero authentication, actively exploited since 2017 by WannaCry, NotPetya, and multiple APT groups (**National Institute of Standards and Technology, 2017a**). The open firewall ensures port 445 is reachable from any subnet. Exploitation yields SYSTEM-level access to the Domain Controller—enabling NTDS.dit extraction (all domain credentials), Golden Ticket creation, Group Policy manipulation, and DNS poisoning. WinRM (port 5985) enables immediate lateral movement to Database and Workstation-Desk.

From a business perspective, exploitation of this vulnerability could interrupt core authentication and directory services, delay recovery across the environment, and expose credentials that affect multiple systems at once.

Likelihood: 5 | Impact: 5 | Risk Score: 25 - Very High

Risk #2 - Firewall Not Enforcing Effective Inter-Subnet Access Controls:

The sole network security device does not appear to be enforcing effective restrictions on inter-subnet traffic, which is inconsistent with the deny-by-default approach recommended by NIST SP 800-41 Rev. 1 (Scarfone & Hoffman, 2009). This conclusion is supported by three independent evidence sources described in Section 2.1. Because traffic between subnets is not meaningfully restricted, nearly every other vulnerability on the network becomes easier to exploit through lateral movement or direct host access. The Production Subnet also appears able to communicate with the Internal Subnet without sufficient filtering, which removes the protection expected from a true DMZ.

From a business perspective, this weakness increases the likelihood that a compromise of one system could spread quickly to others, increasing recovery time and the scope of operational disruption.

Likelihood: 5 | Impact: 5 | Risk Score: 25 - Very High

Risk #3 - SambaCry on Fileshare:

CVE-2017-7494 (CVSS 10.0). Version-confirmed on Samba 4.6.2 (**National Institute of Standards and Technology, 2017b**). Metasploit module available. Achieves root-level RCE on the Fileshare, which shares a broadcast domain with the Domain Controller. Combined with ZeroLogon, provides a two-step path to complete domain compromise.

If exploited, this weakness could disrupt file-sharing services, increase incident response effort, and provide an attacker with a strong internal foothold for further compromise.

Likelihood: 4 | Impact: 5 | Risk Score: 20 - Very High

Risk #4 - Unauthenticated or Weakly Protected Administrative Services on Critical Internal Hosts:

Administrative or management-oriented services exposed without sufficient restriction increase the likelihood of unauthorized access and post-compromise escalation. In this environment, the combination of accessible management interfaces, weak internal segmentation, and unrestricted lateral movement creates multiple paths for deeper compromise without relying on a single software exploit. These conditions increase the chance that an attacker who gains an initial foothold could move toward domain-level assets.

From a business perspective, exploitation of exposed administrative services could accelerate full-environment compromise, interrupt normal operations, and significantly increase recovery complexity.

Likelihood: 4 | Impact: 5 | Risk Score: 20 - Very High

Risk #5 - Unauthenticated JMX Console on Fileshare:

Confirmed accessible without credentials. Violates NIST SP 800-53 Rev. 5 control AC-3 (**Joint Task Force, 2020**). Any host on any subnet can deploy a malicious WAR file through the management console to achieve code execution on the Fileshare with no software vulnerability exploitation required. Provides the easiest initial foothold on the network, chainable with SambaCry or ZeroLogon for domain compromise.

From a business perspective, this risk creates a low-friction path to initial compromise, which could lead to wider service disruption and longer recovery time if used as an entry point for chained attacks.

Likelihood: 5 | Impact: 4 | Risk Score: 20 - Very High

Risk #6 - End-of-Life Operating Systems:

Five hosts plus the firewall run unsupported or outdated platforms that no longer receive regular security updates (**Microsoft, n.d.; FreeBSD Project, n.d.**). Affected systems include the Domain Controller, Database, Workstation-Desk, Backup, and the firewall itself. NIST SP 800-123 requires that unsupported software be replaced (**Souppaya & Scarfone, 2008**). These systems accumulate vulnerabilities permanently with no remediation path.

From a business perspective, unsupported systems increase the long-term cost of remediation, reduce resilience, and make recovery more difficult after a security incident.

Likelihood: 4 | Impact: 5 | Risk Score: 20 - Very High

Risk #7 - Outdated Apache httpd Services:

Multiple hosts run outdated Apache httpd services that may contain known vulnerabilities requiring remediation. Prod-Web is especially important because it is internet-facing and does not appear to benefit from application-layer protection such as a web application firewall. In the current

network design, compromise of an exposed web service could also increase the risk of lateral movement toward internal systems.

From a business perspective, compromise of a web-facing service could affect public availability, reduce trust in the organization's online presence, and increase administrative recovery effort.

Likelihood: 3 | Impact: 4 | Risk Score: 12 - High

Risk #8 - Outdated OpenSSH Services on Windows Hosts:

The Domain Controller, Database, and Workstation-Desk appear to run an outdated OpenSSH version associated with known security concerns and public offensive tooling. Even when a specific CVE requires additional conditions, the continued use of outdated remote administration services increases the need for patching, version validation, and tighter access controls. On critical systems such as the Domain Controller, weaknesses in administrative services can support credential attacks and follow-on compromise.

From a business perspective, weaknesses in remote administration services increase the chance of unauthorized access to critical systems and can expand the impact of a single compromised account.

Likelihood: 3 | Impact: 4 | Risk Score: 12 - High

Risk #9 - Exposed RDP and WinRM:

RDP (port 3389) is exposed on Workstation-Desk. WinRM (port 5985) is open on all three Windows hosts, enabling PowerShell-based lateral movement after any credential compromise. A single compromised credential provides remote shell access to the Domain Controller, Database, and Workstation-Desk simultaneously.

From a business perspective, exposed remote administration services increase the likelihood of rapid compromise of multiple systems, which could delay recovery and disrupt essential business functions.

Likelihood: 3 | Impact: 4 | Risk Score: 12 - High

Risk #10 - Cleartext Protocols:

LDAP, SMTP, POP3, IMAP, FTP, and HTTP transmit credentials and data in plaintext across the network (**Souppaya & Scarfone, 2008**). On the Internal Subnet, where seven hosts share a broadcast domain, any compromised host can passively capture credentials. LLMNR (port 5355) on the Fileshare enables active credential capture via poisoning without prior access.

From a business perspective, exposure of credentials or sensitive communications could lead to unauthorized access, reduced service trust, and additional incident response effort.

Likelihood: 3 | Impact: 4 | Risk Score: 12 - High

Risk #11 - No IDS/IPS, SIEM, EDR:

NIST SP 800-53 Rev. 5 control SI-4 requires system monitoring to detect attacks (Joint Task Force, 2020). During the assessment, active exploitation attempts against EternalBlue and other critical vulnerabilities generated zero alerts. Any exploitation of the vulnerabilities above would go undetected.

From a business perspective, the absence of monitoring increases the likelihood that an attacker could remain undetected longer, resulting in broader damage and more costly recovery activities.

Likelihood: 4 | Impact: 3 | Risk Score: 12 - High

Risk #12 - Inadequate Internal Subnet Segmentation:

Seven hosts share a single broadcast domain including the two most vulnerable systems and a user workstation. NIST SP 800-53 Rev. 5 control SC-7 requires subnetwork isolation (**Joint Task Force, 2020**). The hosts being Layer 2 adjacent enables ARP spoofing, LLMNR poisoning, and passive traffic sniffing that are not possible across routed boundaries.

From a business perspective, poor internal segmentation increases the risk that a localized compromise could spread into a larger operational problem affecting multiple systems and users.

Likelihood: 4 | Impact: 3 | Risk Score: 12 - High

Table 9 - Risk Assessment Summary:

Rank:	Risk:	Host(s):	Likelihood:	Impact:	Risk Score:	Level:
1	EternalBlue (CVE-2017-0143)	Domain Controller	5	5	25	Very High
2	Firewall Not Enforcing Effective Inter-Subnet Access Controls	Firewall	5	5	25	Very High
3	SambaCry (CVE-2017-7494)	Fileshare	4	5	20	Very High
4	With: Exposed Administrative Services on Critical Internal Hosts	Fileshare	4	5	20	Very High
5	JMX Console Unauthenticated	Fileshare	5	4	20	Very High
6	End-of-Life Operating Systems	5 hosts + Firewall	4	5	20	Very High
7	Outdated Apache httpd	Backup, Dev-Web, Prod-Web, Mail	3	4	12	High
8	Outdated OpenSSH Services	Domain Controller, Database, Workstation-Desk	3	4	12	High
9	Exposed RDP + WinRM	Workstation-Desk, Domain Controller, Database	3	4	12	High
10	Cleartext Protocols	Mail, Backup, Domain Controller, +5	3	4	12	High
11	No IDS/IPS/SIEM/EDR	Entire network	4	3	12	High
12	Inadequate Segmentation	Internal Subnet	4	3	12	High

3.3. Attack Path Analysis

Taken together, the identified risks create multiple plausible attack paths that could lead to severe organizational compromise, including the following:

- **Path A: Direct Domain Compromise**

Any Subnet > EternalBlue (Port 445) > Domain Controller SYSTEM shell > NTDS.dit extraction > credential compromise > WinRM-based lateral movement to Database and Workstation-Desk.

- **Path B: Fileshare Pivot**

Any Subnet > JMX Console (no authentication) > Fileshare code execution > internal pivoting toward administrative services or credential material > Domain Controller compromise.

- **Path C: Internal to Internal**

Internet > Prod-Web compromise > foothold in the Production Subnet > inadequate inter-subnet filtering > movement into internal systems > exploitation of high-risk internal vulnerabilities > domain compromise.

- **Path D: Passive Credential Harvesting**

Compromised internal host > LLMNR poisoning or passive credential capture > credential recovery > use of exposed remote administration services > domain compromise.

Each of these potential attack paths illustrates how the identified weaknesses can reinforce one another and increase the likelihood of severe compromise. In the current environment, weak inter-subnet controls and limited monitoring reduce both prevention and detection capability. This combination makes containment more difficult once an attacker gains an initial foothold.

4. Recommendations (Task 3)

The following recommendations address the risks identified in Section 3. They are organized into five areas that align with the project requirements including updated network architecture,

additional security tools, device-specific configurations, attack surface reduction, and an implementation roadmap. The recommendations are intended to provide practical, implementable improvements that directly address the weaknesses identified during the assessment.

4.1. Updated Network Architecture

The current network architecture relies on weak internal separation and does not appear to enforce effective inter-subnet access controls. The recommended architecture introduces VLAN-based segmentation, a true DMZ, and explicit access controls between network segments in alignment with firewall best practices (**Scarfone & Hoffman, 2009**).

Figure 11 - Recommended Network Architecture:

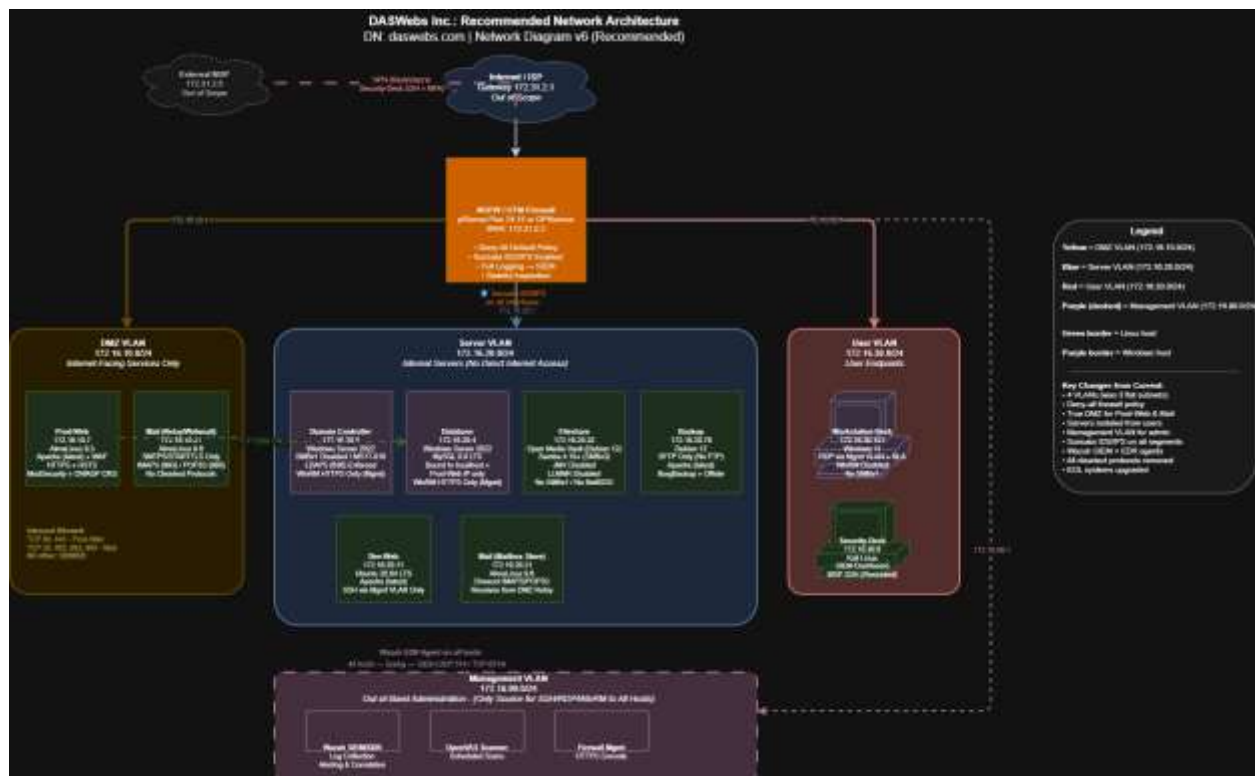


Table 10 - Recommended VLAN Allocation:

VLAN:	Subnet:	Purpose:	Hosts:
DMZ	172.16.10.0/24	Internet-facing services only	Prod-Web, Mail (SMTP relay/webmail frontend)

Server	172.16.20.0/24	Internal servers - no direct internet access	Domain Controller, Database, Dev-Web, Fileshare, Backup, Mail (mailbox store)
User	172.16.30.0/24	User endpoints	Workstation-Desk, Security-Desk
Management	172.16.99.0/24	Out-of-band administration, SIEM, scanning	SIEM, vulnerability scanner, firewall management

Table 11 - Recommended Firewall Rules (Default Deny-All):

Source > Destination:	Allowed Traffic:	Reasoning:
Internet > DMZ (Prod-Web)	TCP 80, 443	Public web access only
Internet > DMZ (Mail relay)	TCP 25, 465, 993, 995	Email services only
Internet > Server/User	All Denied	No direct internet access to internal hosts
DMZ (Prod-Web) > Server (Database)	TCP 3306	Application-to-database communication only
User > Server (Fileshare)	TCP 445 (SMBv3 only)	File access - no SMBv1 or NFS
User > Server (Mail store)	TCP 993, 995	Encrypted email retrieval only
User > Internet	TCP 80, 443 via proxy	Filtered outbound web access
Management > All	SSH, RDP, HTTPS (management)	Administrative access from Management VLAN only
All > Management	Syslog (UDP 514 / TCP 6514)	Log forwarding to SIEM

This architecture significantly reduces the attack paths identified in Section 3.3 by introducing segmentation, restricting management access, and limiting inter-VLAN communication to approved services only. Access to SMB, WinRM, SSH, and other management services is restricted, the DMZ is separated from internal systems, and user endpoints no longer share a broadcast domain with critical servers. As a result, lateral movement becomes more difficult and several previously identified attack paths are either blocked outright or substantially mitigated.

4.2. Recommended Security Tools

Table 12 - Recommended Security Tools by Priority:

Priority:	Tool:	Recommended Product:	Purpose:	Addresses Risk #:
-----------	-------	----------------------	----------	-------------------

Immediate	Next-Generation Firewall	OPNsense or pfSense Community Edition (open-source), or FortiGate 60F (commercial)	Replace EOL pfSense 2.5.0; enforce deny-all policy with logging	#2, #6
Immediate	IDS/IPS	Suricata (integrated with pfSense Plus)	Detect and block exploitation attempts across all segments (Open Information Security Foundation, n.d.)	#11
Immediate	EDR	Wazuh Agent (open-source) on all hosts	File integrity monitoring, rootkit detection, active response (Wazuh, Inc., n.d.)	#11
30 days	SIEM	Wazuh Manager (open-source)	Centralized log collection, correlation, and alerting on Management VLAN (Wazuh, Inc., n.d.)	#11
30 days	WAF	ModSecurity with OWASP Core Rule Set on Prod-Web	Application-layer protection for public WordPress site	#7
30 days	Vulnerability Scanner	OpenVAS / Greenbone Community Edition	Scheduled scanning and patch verification from Management VLAN	#6, #7, #8
60 days	Patch Management	WSUS (Windows) + Ansible (Linux)	Automated patching after OS upgrades	#6
60 days	Backup Solution	BorgBackup with off-site replication	Air-gapped backups resistant to ransomware	#6

The recommended open-source tools reduce cost barriers to implementation while still providing meaningful security improvements for this environment. Wazuh provides centralized log collection, alerting, and host-monitoring capabilities by combining the Wazuh Manager with endpoint agents in a single management platform.

4.3. Device-Specific Configurations

Table 13 - Recommended Configurations by Device:

Device:	Configuration Change:	Current State:	Recommended State:
Firewall	Operating system	pfSense 2.5.0 (EOL)	pfSense Plus 24.11 or OPNsense (current)
	Firewall policy	Overly permissive inter-subnet access	Deny-all default
	IDS/IPS	None	Suricata with ET Open ruleset on all interfaces
	Logging	None	Log all deny rules; forward to SIEM
	VPN (MSP access)	Unrestricted internal access	Restrict to Security-Desk SSH only; enforce MFA
	Web management	HTTP/HTTPS on all interfaces	Management VLAN only; HTTPS only
Domain Controller	SMBv1	Enabled (EternalBlue confirmed)	Disable immediately; apply MS17-010
	Operating system	Windows Server 2012 R2 (EOL)	Windows Server 2022
	OpenSSH	7.1 (32 CVEs)	Upgrade to a current supported version or remove if not required
	WinRM	Port 5985, unrestricted	Management VLAN only; require HTTPS (5986)
	LDAP	Port 389, cleartext	Enforce LDAPS (636) with certificate validation
	NetBIOS	Broadcasting host role	Disable NetBIOS over TCP/IP
Fileshare	Samba	4.6.2 with known security exposure	Upgrade immediately to a current supported version
	JMX Console	No authentication required	Disable or restrict to Management VLAN with authentication
	LLMNR	Port 5355 active	Disable
	RPC/NFS-related services	Ports 2049/111 open	Disable if not required, or replace with SMBv3 or

			NFSv4 with stronger security controls
	NFS/RPCBind	Ports 2049/111 open	Replace with SMBv3 or implement NFSv4 with Kerberos
Database	Operating system	Windows Server 2012 R2 (EOL)	Windows Server 2022
	MySQL	5.7.21 (EOL)	MySQL 8.0 LTS
	OpenSSH	7.1 (32 CVEs)	Upgrade to a current supported version or remove if not required
	WinRM	Port 5985, unrestricted	Management VLAN only; HTTPS (5986)
	MySQL binding	All interfaces	Localhost + Prod-Web IP only
Prod-Web	Apache	2.4.53 (49 CVEs)	Latest 2.4.x
	HTTP TRACE	Enabled	TraceEnable Off
	HTTPS	Not enforced	Let's Encrypt certificate; redirect HTTP to HTTPS; HSTS
	WAF	None	ModSecurity with OWASP CRS
	WordPress login	/wp-login.php unrestricted	IP restriction + CAPTCHA
Mail	POP3/IMAP	Cleartext (110/143)	Disable cleartext; enforce POP3S (995) / IMAPS (993) only
	SMTP	Cleartext (25)	Enforce STARTTLS; implement SMTPS (465)
	Apache	2.4.62 (23 CVEs)	Latest 2.4.x
Backup	Operating system	Debian 9 (EOL)	Debian 12 "Bookworm"
	FTP	vsftpd 3.0.3, cleartext	Remove entirely; use SFTP via SSH
	Apache	2.4.25 (90 CVEs)	Latest 2.4.x (included with Debian 12)
	MediaWiki	/setup/ directory exposed	Remove setup directory; restrict account creation
Workstation-Desk	Operating system	Windows 10 Pro 1809 (EOL)	Windows 11
	RDP	Port 3389, unrestricted	Management VLAN only; enable NLA; enforce TLS
	WinRM	Port 5985 open	Disable - not appropriate for user workstations
	OpenSSH	7.1 (32 CVEs)	Upgrade to a current supported version or remove if not required

4.4. Attack Surface Reduction

Table 14 - Services to Eliminate:

Service:	Port:	Host:	Action:	Replacement:
FTP	21	Backup	Remove	SFTP via SSH
POP3 (cleartext)	110	Mail	Disable	POP3S (995)
IMAP (cleartext)	143	Mail	Disable	IMAPS (993)
RPCBind	111	Fileshare	Disable	NFSv4 or SMBv3 (no RPCBind required)
NetBIOS	139	4 hosts	Disable	SMBv3 over port 445
LLMNR	5355	Fileshare	Disable via GPO	DNS
SMBv1 (protocol)	445	All SMB hosts	Disable protocol	SMBv3 with encryption
HTTP TRACE	80	Prod-Web	Disable	N/A
JMX Console	80	Fileshare	Disable or authenticate	Management VLAN access only

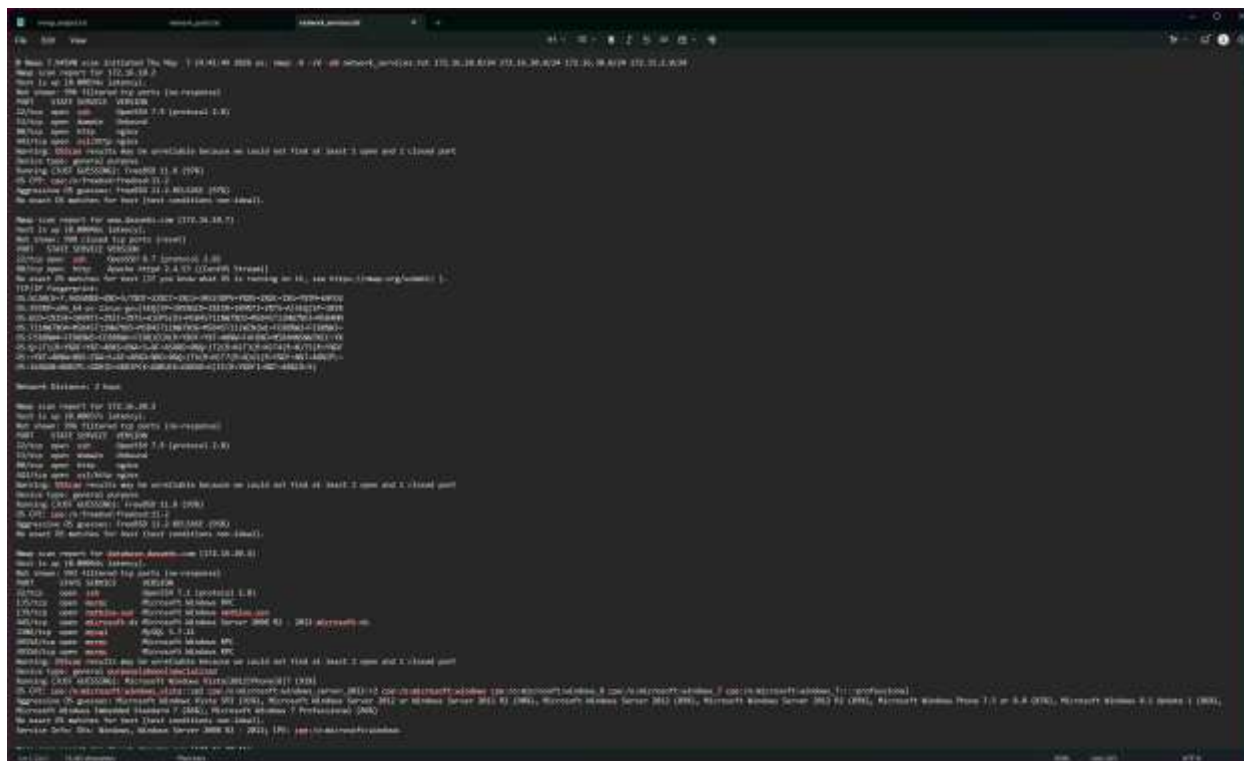
Table 15 - Protocols to Upgrade:

Current Protocol:	Host:	Upgrade To:	Key Benefit:
LDAP (389)	Domain Controller	LDAPS (636)	Encrypts directory queries and authentication
SMTP (25)	Mail	SMTPS (465) / STARTTLS	Encrypts email in transit
NFS (2049)	Fileshare	NFSv4 with Kerberos or SMBv3	Adds authentication and encryption
WinRM HTTP (5985)	3 Windows hosts	WinRM HTTPS (5986)	Encrypts remote management
HTTP (80)	6 hosts	HTTPS with HSTS	Encrypts all web traffic
SSH (various)	Administrative hosts and servers where required	Current supported OpenSSH version with modern key-based authentication	Reduces exposure in remote administration services and strengthens management access

Eliminating unnecessary services and upgrading weak protocols would significantly reduce the network attack surface. Restricting SSH and other management interfaces to the Management VLAN reduces exposure of administrative services and makes unauthorized access more difficult. In addition, a

deny-all firewall policy limits unrestricted cross-subnet communication, while disabling NetBIOS and similar legacy features reduces opportunities for passive reconnaissance and credential-related attacks.

Figure 12 - DASWebs Inc. Nmap Services Scan:



4.5. Implementation Roadmap

Table 16 - Phased Implementation Plan:

Phase:	Timeline:	Actions to Take:	Risks Addressed:
1 - Emergency	0-48 Hours	Disable SMBv1 on Domain Controller. Apply MS17-010. Disable JMX Console on Fileshare. Configure firewall deny-all default policy.	#1, #2, #5
2 - Critical	1-2 Weeks	Upgrade Samba to 4.19+. Upgrade firewall OS. Enable Suricata IDS/IPS. Deploy Wazuh agents. Disable FTP on Backup. Disable	#3, #4, #6, #10, #11

		cleartext POP3/IMAP on Mail.	
3 - High	2-4 Weeks	Upgrade Apache and OpenSSH on all hosts. Implement VLAN segmentation per Table 8. Deploy WAF on Prod-Web. Enforce LDAPS. Disable LLMNR/NetBIOS network-wide.	#7, #8, #10, #12
4 - Medium	1-3 Months	Migrate Domain Controller and Database to Windows Server 2022. Upgrade Workstation-Desk to Windows 11. Upgrade Backup to Debian 12. Deploy SIEM. Implement Management VLAN.	#6, #9, #11
5 - Ongoing	Continuous	Monthly vulnerability scanning. Automated patch management. Security awareness training. Annual penetration testing.	All

Phase 1 addresses the two highest-priority risks, EternalBlue and ineffective firewall access control, within 48 hours using configuration changes that do not require major new procurement. Each subsequent phase builds on the previous one so that security improvements are introduced in a practical order without creating unnecessary implementation gaps.

5. Conclusion

The security assessment of the DASWeb Inc. network revealed critical deficiencies across all evaluated areas. Six of the twelve prioritized risks were rated at the Very High level, including the EternalBlue vulnerability on the Domain Controller and the firewall's failure to enforce effective inter-subnet access controls. Together, these weaknesses significantly increase the likelihood of lateral movement, widespread compromise, and delayed detection across the environment. The network's

reliance on unsupported systems, weak internal segmentation, cleartext protocols, and limited monitoring further increases overall risk.

The recommendations provided in Section 4 address the identified risks through a phased implementation roadmap that starts with emergency actions achievable within the first 48 hours and then progresses to longer-term architectural and administrative improvements. Full implementation of the recommended design, including VLAN segmentation, a deny-all firewall policy, IDS/IPS deployment, centralized logging, and stronger endpoint monitoring, would significantly improve the security posture of the DASWebs Inc. network and establish a stronger baseline for ongoing security management and maintenance.

6. References

Cybersecurity and Infrastructure Security Agency. (2020, October 9). *APT actors chaining vulnerabilities against SLTT, critical infrastructure, and elections organizations (Alert AA20-283A)*.

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-283a>

Cybersecurity and Infrastructure Security Agency. (n.d.-a). *Known exploited vulnerabilities catalog*.

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

FreeBSD Project. (n.d.). *Unsupported FreeBSD releases*. <https://www.freebsd.org/security/unsupported/>

Joint Task Force. (2020). *Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Revision 5)*. National Institute of Standards and Technology.

<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

Microsoft. (n.d.). *Search product and services lifecycle information - Microsoft SQL Server 2012*.

<https://learn.microsoft.com/en-us/lifecycle/products/microsoft-sql-server-2012>

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments (Special Publication 800-30, Revision 1)*. U.S. Department of Commerce.

<https://csrc.nist.gov/pubs/sp/800/30/r1/final>

National Institute of Standards and Technology. (2017a). CVE-2017-0143 detail. National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/cve-2017-0143>

National Institute of Standards and Technology. (2017b). CVE-2017-7494 detail. National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/CVE-2017-7494>

Open Information Security Foundation. (n.d.). Suricata: Open source IDS/IPS. <https://suricata.io/>

Scarfone, K., & Hoffman, P. (2009). *Guidelines on firewalls and firewall policy (NIST Special Publication 800-41, Revision 1)*. National Institute of Standards and Technology.

<https://csrc.nist.gov/pubs/sp/800/41/r1/final>

Souppaya, M., & Scarfone, K. (2008). *Guide to general server security (NIST Special Publication 800-123)*.

National Institute of Standards and Technology. <https://csrc.nist.gov/pubs/sp/800/123/final>

Wazuh, Inc. (n.d.). *Wazuh: The open source security platform*. <https://wazuh.com/>

7. Appendix

Appendix A: Assessment Timeline

Date & Time (UTC):	Source, Description, and Action Taken:
2026-05-06 21:07:47	Source: Ryan-Legion Description: Accessed and documented the XP Cyber Range: A Sense of Security [NG] lab environment starting condition required for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From Ryan-Legion, accessed the XP Cyber Range - Manage Workspace page located at https://range.xpcyber.com/workspace/329110 to assess the initial state of the lab environment. 2. From the XP Cyber Range - Manage Workspace page, observed and documented the following: a. Virtual Machines b. Checks c. Challenge Info d. Meeting Notes e. Network Map i. It should be noted that while the Checks section lists a singular green check, the description states "There are no checks for this Challenge."
2026-05-06 21:20:21	Source: Security-Desk Description: Accessed the Security-Desk workstation and initiated a nmap vulnerability scan against all subnets in the DASWebs Inc. network, required for the security assessment for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Security-Desk entry under the Virtual Machines tab to access the Security-Desk workstation. 2. From the Security-Desk workstation login screen, utilized the Username: playerone and Password: password123 to login. 3. From the Security-Desk workstation desktop, selected the Terminal Emulator shortcut from the top taskbar to open a new bash terminal session. 4. From the Security-Desk Terminal Emulator, utilized the command <code>'\$ sudo nmap -sV -sC --script vuln -oA daswebs_vuln_scan 172.16.10.0/24 172.16.20.0/24 172.16.30.0/24 ></code>

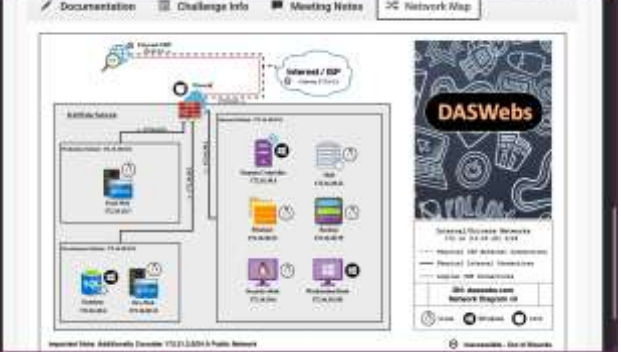
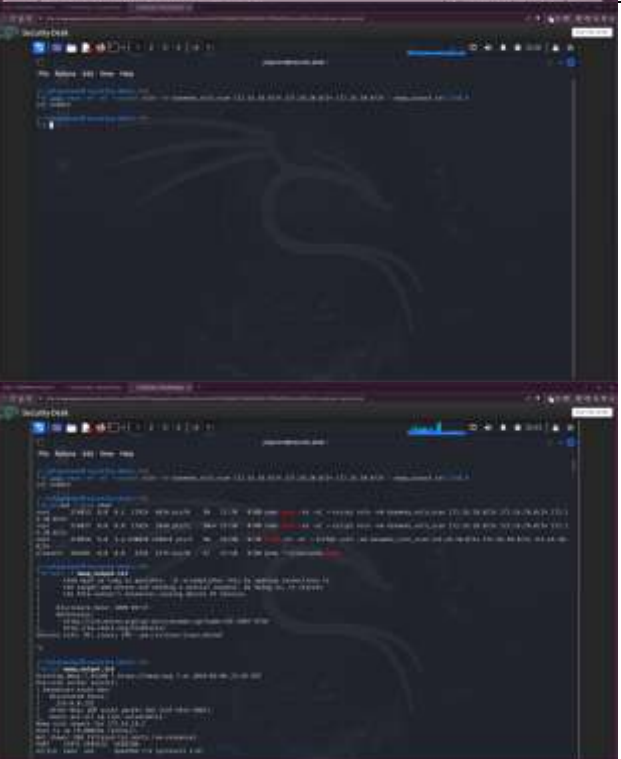
	nmap_output.txt 2>&1 &' to conduct a nmap vulnerability scan that does the following: -sV: Version Detection -sC: Default Scripts --script vuln: Run all vulnerability detection scripts -oA: Output results in all formats including normal, XML, and greppable. - Additionally, it should be noted that the additional '&' at the end of the command instructs the shell to run the scan in the background. - From the Security-Desk Terminal Emulator, within the nmap vulnerability scan output, observed the nmap vulnerability scan process ID to be "[1] 376055". - From the Security-Desk Terminal Emulator, executed the command '\$ ps aux grep nmap' to verify the nmap scan was successfully running in the background.
2026-05-06 21:53:04	Source: Ryan-Legion Description: Conducted intensive research on the most effective and efficient methods for collecting security data from both Linux and Windows-based systems including scripts, required for the security assessment for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: - From Ryan-Legion, conducted intensive review to identify the method that would most consistently and efficiently collect the security data required to provide a comprehensive, high-quality security assessment of the DASWebs Inc. network. - My research findings indicated that the most consistent, effective method for collecting the data for my assessment would be to utilize scripts to automate scanning. - From Ryan-Legion, utilized an internet search to identify several pre-existing scripts utilized for security data collection that could be easily modified to suit the needs of the security scans required for the CNG 2059: Enterprise Security - Capstone Project. - From the Security-Desk Terminal Emulator, utilized the command '\$ nano linux_security_script.txt' to create a file name linux_security_script.txt containing the security scanning script to be utilized on Linux systems including Prod-Web and Dev-Web. - From the Security-Desk Desktop, opened the text editor and created the windows_security_script.ps1 file containing the PowerShell script to be utilized on Windows systems including Database and Domain Controller.
2026-05-06 22:17:07	Source: Security-Desk Description: Secure copied the previously created Linux and Windows scripts to Prod-Web, Dev-Web, Database, and Domain Controller in

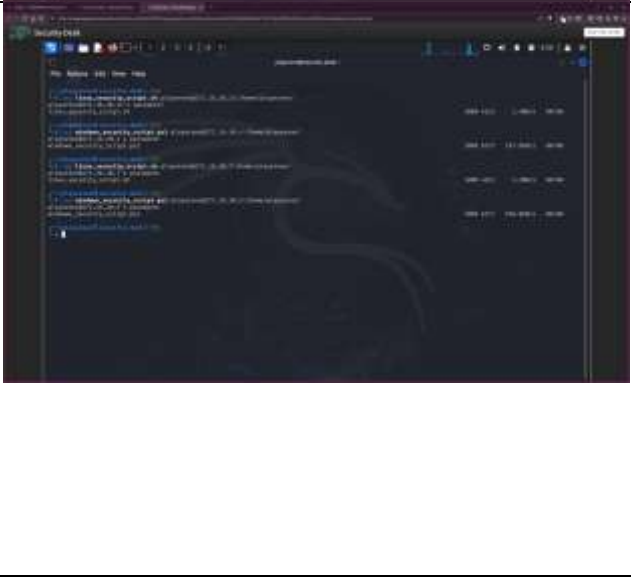
	preparation for the security assessment of the DASWebs Inc. network for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From Security-Desk Terminal Emulator, utilized the command '<code>\$ scp linux_security_script.sh playerone@172.16.20.11:/home/playerone/</code>' to secure copy the linux_security_script.sh file to the Dev-Web workstation. 2. From Security-Desk Terminal Emulator, utilized the command '<code>\$ scp windows_security_script.ps1 playerone@172.16.20.4:/home/playerone/</code>' to secure copy the windows_security_script.ps1 file to the Database workstation. 3. From Security-Desk Terminal Emulator, utilized the command '<code>\$ scp linux_security_script.sh playerone@172.16.10.7:/home/playerone/</code>' to secure copy the linux_security_script.sh file to the Prod-Web workstation. 4. From Security-Desk Terminal Emulator, utilized the command '<code>\$ scp windows_security_script.ps1 playerone@172.16.30.5:/home/playerone/</code>' to secure copy the windows_security_script.ps1 file to the Domain Controller workstation.
2026-05-06 22:32:04	Source: Security-Desk; Prod-Web Description: Executed the previously created linux_security_script.sh script on the Prod-Web workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the Security-Desk Terminal Emulator, executed the command '<code>\$ ssh playerone@172.16.10.7</code>' to ssh into the Prod-Web workstation. 2. From the Prod-Web ssh shell, executed the command '<code>\$ sudo ./linux_security_script.sh</code>' to execute the security data collection script, which successfully executed with a message stating that all output could be found in /home/playerone/security_assessment_20260506_220655. 3. From the Security-Desk Terminal Emulator, executed the command '<code>\$ scp -r playerone@172.16.10.7:/home/playerone/security_assessment_20260506_220655 ~/security_assessment_results/</code>' to copy the results of the scan on Prod-Web over to the Security-Desk workstation for analysis and export to Ryan-Legion.
2026-05-07 13:20:15	Source: XP Cyber Range - Manage Workspace; Database; Security-Desk Description: Executed the previously created windows_security_script.ps1 script on the Database workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Database entry

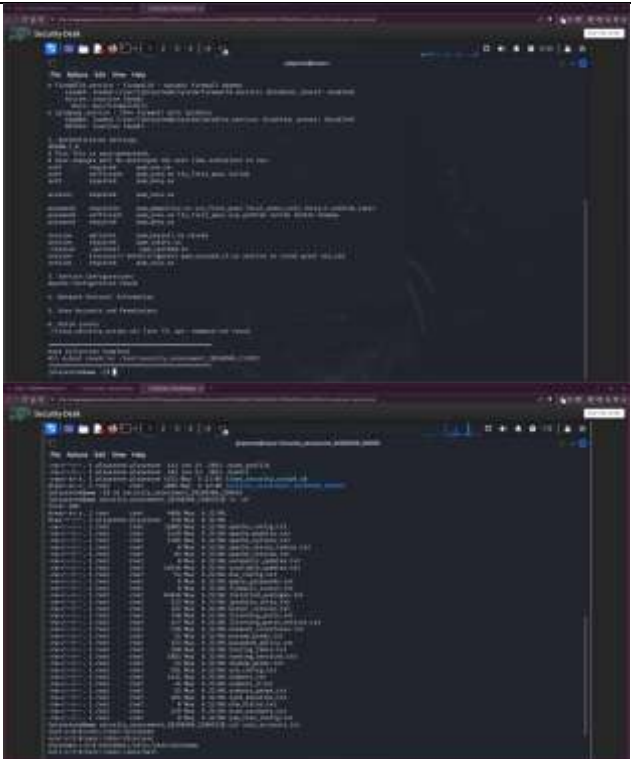
	under the Virtual Machines tab to access the Database workstation. - From Database workstation desktop, right-clicked on the Windows Start Menu and selected 'Command-Line Prompt (Admin)' from the resulting menu. - From the Database CLI terminal, switched to the directory containing the windows_security_script.ps1 file using the command '> cd C:\Users\playerone\' and executed the security data collection script with the command '> .\windows_security_script.ps1', which successfully executed and output the security data to the C:\security_assessment_20260507_190505 directory. - From the Security-Desk Terminal Emulator, utilized the command '\$ ssh playerone@172.16.20.4' to connect to the Database workstation via SSH before moving into the security_assessment_20260507_190505 directory and utilizing the command 'pwd' to print the working directory, which was observed to be /cygdrive/c/security_assessment_20260507_190505. - From the Security-Desk Terminal Emulator, utilized the command '\$ scp -r playerone@172.16.20.4:/cygdrive/c/security_assessment_20260507_190505 ~/security-assessment-results/database/' to secure copy the collected security data from Database to Security-Desk for analysis and export to Ryan-Legion.
2026-05-07 14:25:00	Source: XP Cyber Range - Manage Workspace; Dev-Web; Security-Desk Description: Executed the previously created linux_security_script.sh script on the Dev-Web workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: - From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Dev-Web entry under the Virtual Machines tab to access the Database workstation. - From the Dev-Web terminal, utilized the command '\$ ls -al' to verify the presence of the Linux security script on Dev-Web before executing the command '\$./linux_security_script.sh' to run the security data collection script, which successfully completed and output the data to the /home/playerone/security_assessment_20260507_202029 directory. - From the Security Desk terminal, utilized the command '\$ scp -r playerone@172.16.20.11:/root/security_assessment_* ~/security-assessment-results/dev-web/' to secure copy the collected security data from Dev-Web to Security-Desk for analysis and export to Ryan-Legion.
2026-05-07 14:40:57	Source: XP Cyber Range - Manage Workspace; Domain Controller; Security-Desk

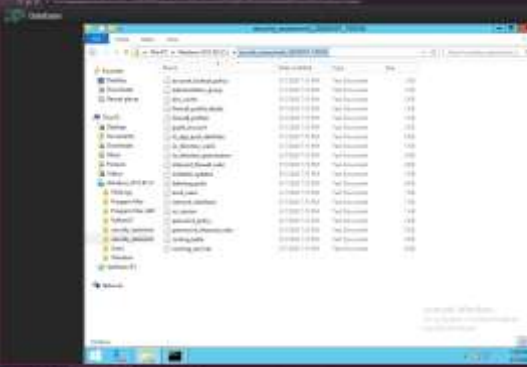
	Description: Executed the previously created windows_security_script.ps1 script on the Domain Controller workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Domain Controller entry under the Virtual Machines tab to access the Domain Controller workstation. 2. From Domain Controller workstation desktop, right-clicked on the Windows Start Menu and selected 'Command-Line Prompt (Admin)' from the resulting menu. 3. From the Database CLI terminal, switched to the directory containing the windows_security_script.ps1 file using the command '> cd C:\Users\playerone\' and executed the security data collection script with the command '> .\windows_security_script.ps1', which successfully executed and output the security data to the C:\security_assessment_20260507_200527 directory. 4. From the Security-Desk Terminal Emulator, utilized the command '\$ ssh playerone@172.16.30.5' to connect to the Database workstation via SSH before moving into the security_assessment_20260507_190505 directory and utilizing the command 'pwd' to print the working directory, which was observed to be /cygdrive/c/security_assessment_20260507_200527. 5. From the Security-Desk Terminal Emulator, utilized the command '\$ scp -r playerone@172.16.30.5:/cygdrive/c/security_assessment_20260507_200527 ~/security-assessment-results/domain-controller/' to secure copy the collected security data from Domain Controller to Security-Desk for analysis and export to Ryan-Legion.
2026-05-07 15:15:34	Source: XP Cyber Range - Manage Workspace; Firewall; Security-Desk Description: Accessed and executed several commands on the Firewall shell to gather data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Firewall entry under the Virtual Machines tab to access the Firewall interface. 2. From the Firewall interface, selected '8) Shell' from the login screen and executed the command 'sudo find /etc -name "*firewall*" -type f' to locate files with firewall in the name, identifying the path /etc/rc.firewall 3. From the Security-Desk terminal, utilized the command '\$ scp -r admin@172.16.10.2:/etc/rc.firewall ~/security_assessment_results/firewall/' to secure copy the

	rc.firewall file from Firewall to Security-Desk for analysis and export to Ryan-Legion. 4. Additionally, from the Security-Desk terminal, utilized the command '<code>\$ scp -r admin@172.16.10.2:/~/security_assessment_results/firewall/</code>' to secure copy a complete backup of Firewall to Security-Desk for analysis and export to Ryan-Legion.
2026-05-07 16:14:25	Source: XP Cyber Range - Manage Workspace; Security-Desk Description: Executed a series of tcpdump and nmap commands against all three subnets and the DASWebs Inc. network to gather data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the XP Cyber Range - Manage Workspace page, selected the HTML5 button located to the right of the Security-Desk entry under the Virtual Machines tab to access the Security-Desk workstation. 2. From the Security-Desk terminal, utilized the command '<code>\$ sudo tcpdump -i any -w daswebs_traffic.pcap -c 10000</code>' to capture traffic on all network interfaces for 10000 packets and then save the output to the file daswebs_traffic.pcap. 3. From the Security-Desk terminal, utilized the command '<code>\$ sudo nmap -sn -PE -PP -PS22,23,80,443,3389 -PA21,23,80,443,3389 -PU -PY -PO --traceroute -oN network_map.txt 172.16.10.0/24 172.16.20.0/24 172.16.30.0/24 172.31.2.0/24</code>' to perform a comprehensive network scan for providing a detailed network map. 4. From the Security-Desk terminal, utilized the command '<code>\$ sudo nmap -O -sV -oN network_services.txt 172.16.10.0/24 172.16.20.0/24 172.16.30.0/24 172.31.2.0/24</code>' to perform an OS and service detection scan and save the output to the file network_services.txt'. 5. From the Security-Desk terminal, utilized the command '<code>\$ sudo nmap -p- -T4 -oN network_ports.txt 172.16.10.0/24 172.16.20.0/24 172.16.30.0/24 172.31.2.0/24</code>' to perform a full TCP port scan and save the output to a file called network_ports.txt.
2026-05-07 18:23:19	Source: Security-Desk; Firewall Description: Accessed the Firewall Web UI and gathered additional data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project. Action Taken: 1. From the Security-Desk desktop, selected the Firefox shortcut from the top taskbar to open a new browser window and navigated to the Firewall Web UI located at https://172.31.2.2 to gather additional information for the security assessment. 2. From the Firewall Web UI, navigated to Firewall > Rules in the top menu to investigate and gather screenshots of the Firewall

		 
2026-05-06 21:20:21	Accessed the Security-Desk workstation and initiated a nmap vulnerability scan against all subnets in the DASWebs Inc. network, required for the security assessment for the CNG 2059: Enterprise Security - Capstone Project.	

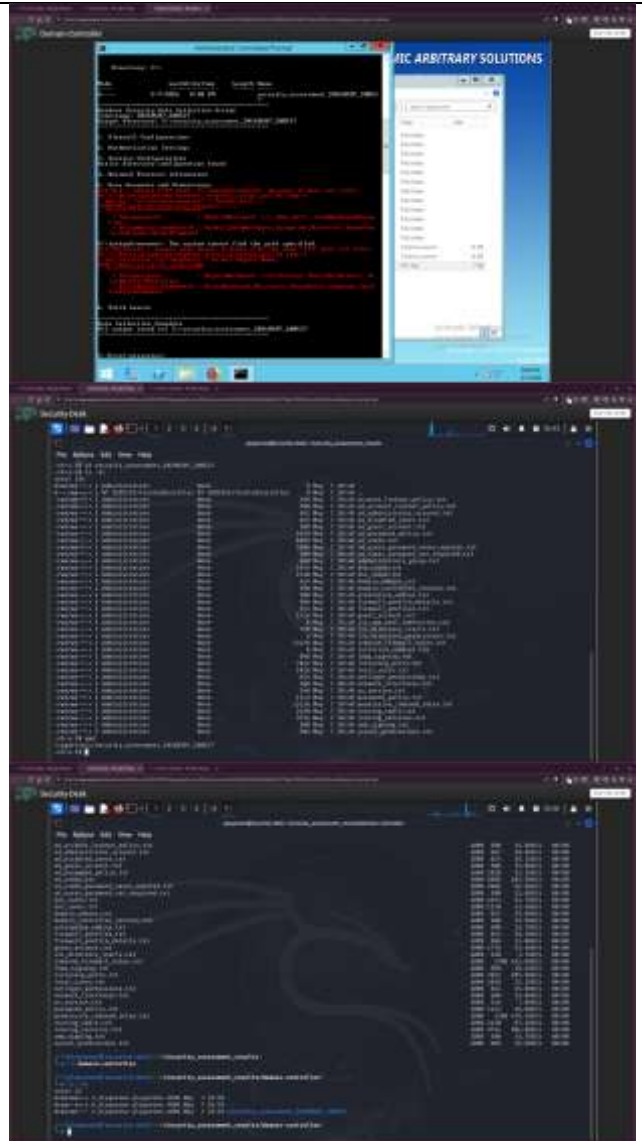
2026-05-06 21:53:04	Conducted intensive research on the most effective and efficient methods for collecting security data from both Linux and Windows-based systems including scripts, required for the security assessment for the CNG 2059: Enterprise Security - Capstone Project.	
2026-05-06 22:17:07	Secure copied the previously created Linux and Windows scripts to Prod-Web, Dev-Web, Database, and Domain Controller in preparation for the security assessment of the DASWebs Inc. network for the CNG 2059: Enterprise	

	Security - Capstone Project.	
2026-05-06 22:32:04	Executed the previously created linux_security_script.sh script on the Prod-Web workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project.	
2026-05-07 13:20:15	Executed the previously created windows_security_script.ps1 script on the Database workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project.	

		
2026-05-07 14:25:00	Executed the previously created linux_security_scr ipt.sh script on the Dev-Web workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project.	

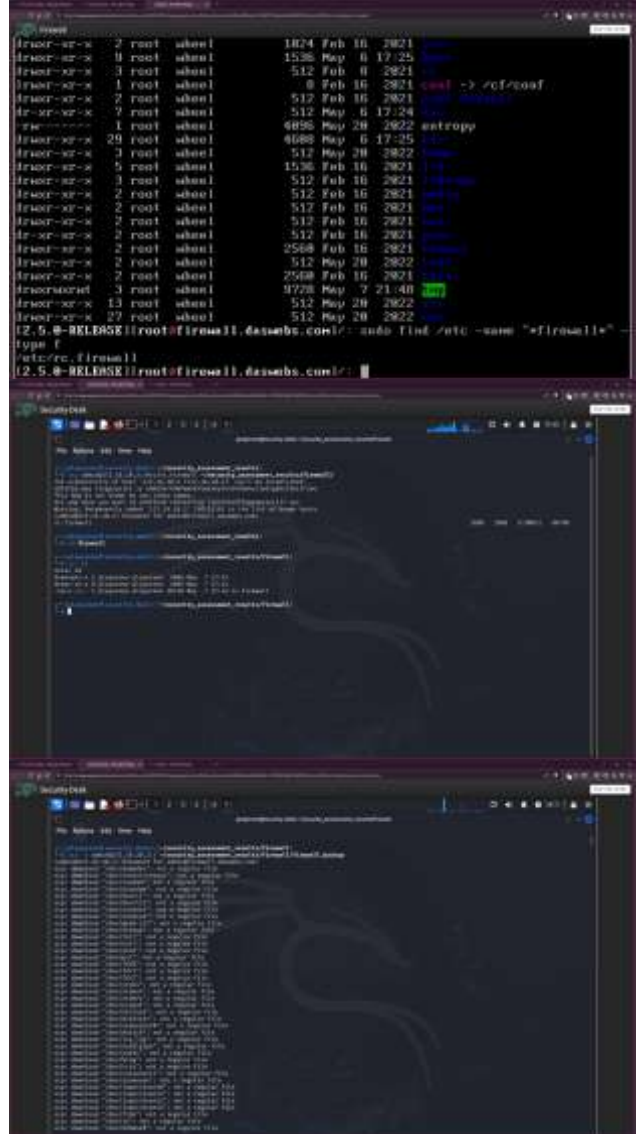
2026-05-07 14:40:57

Executed the previously created windows_security_script.ps1 script on the Domain Controller workstation to gather the security data necessary for the CNG 2059: Enterprise Security - Capstone Project.



2026-05-07 15:15:34

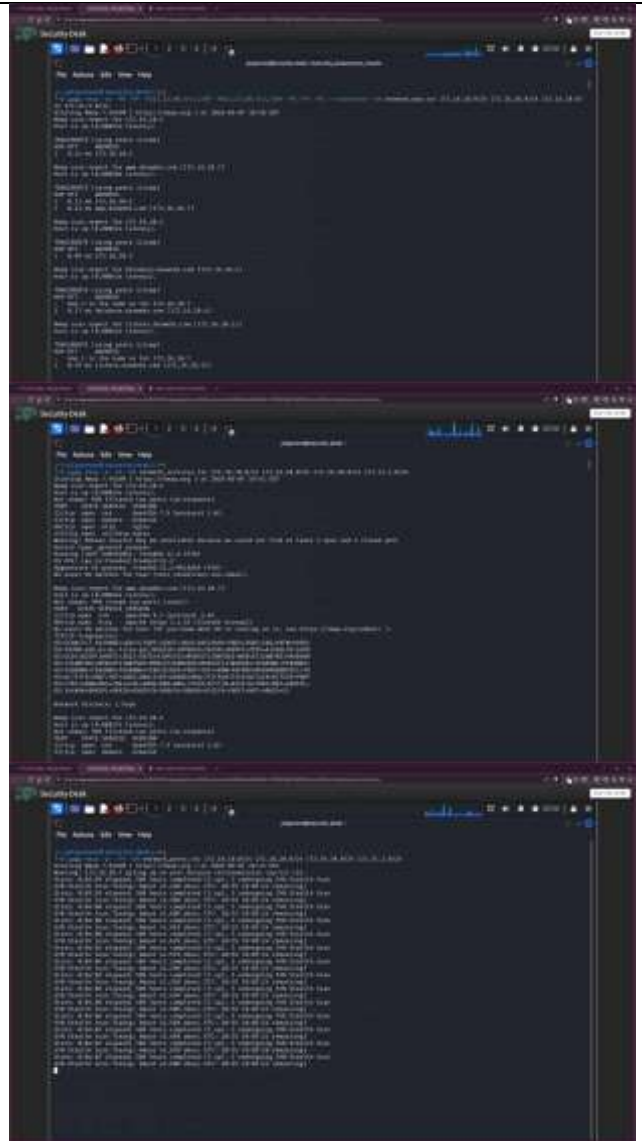
Accessed and executed several commands on the Firewall shell to gather data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project.



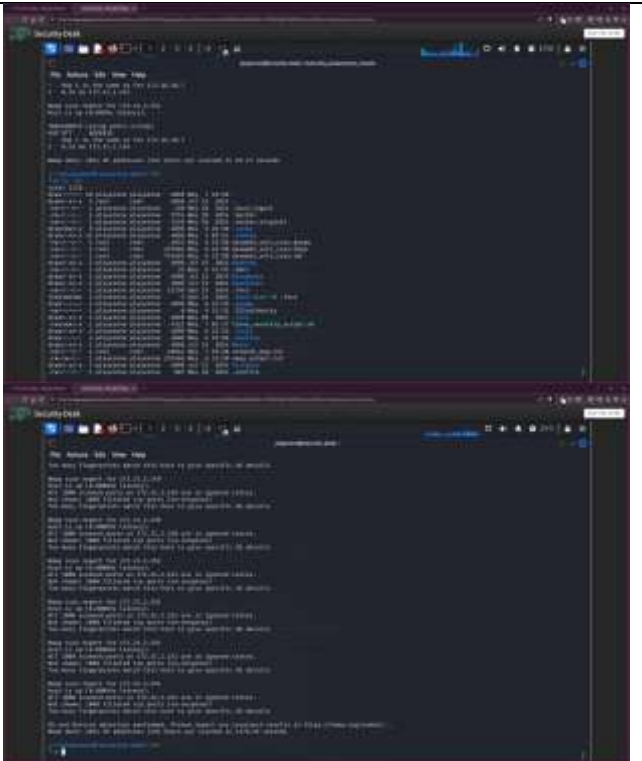
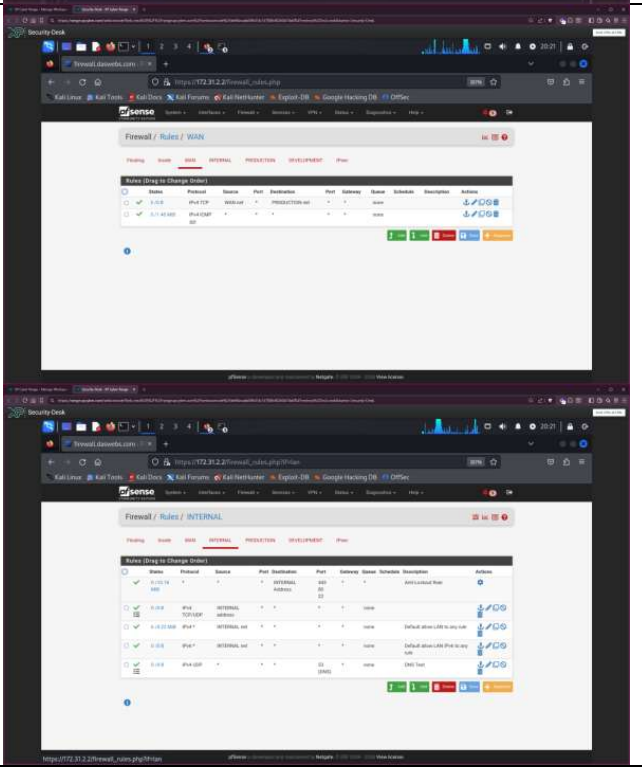
```
root
tracer-xp-x 2 root admin 1024 Feb 16 2021 [root]
tracer-xp-x 0 root admin 1536 May 6 17:25 [root]
tracer-xp-x 3 root admin 512 Feb 8 2021 [root]
tracer-xp-x 1 root admin 0 Feb 16 2021 [root] -> /etc/passwd
tracer-xp-x 2 root admin 512 Feb 16 2021 [root]
tracer-xp-x 7 root admin 512 May 6 17:25 [root]
tracer-xp-x 1 root admin 4096 May 20 2022 entropy
tracer-xp-x 29 root admin 4096 May 6 17:25 [root]
tracer-xp-x 3 root admin 512 May 20 2022 [root]
tracer-xp-x 5 root admin 1536 Feb 16 2021 [root]
tracer-xp-x 3 root admin 512 Feb 16 2021 [root]
tracer-xp-x 2 root admin 512 Feb 16 2021 [root]
tracer-xp-x 2 root admin 512 Feb 16 2021 [root]
tracer-xp-x 2 root admin 512 Feb 16 2021 [root]
tracer-xp-x 2 root admin 2560 Feb 16 2021 [root]
tracer-xp-x 2 root admin 512 May 20 2022 [root]
tracer-xp-x 2 root admin 2560 Feb 16 2021 [root]
tracer-xp-x 3 root admin 9728 May 7 21:40 [root]
tracer-xp-x 13 root admin 512 May 20 2022 [root]
tracer-xp-x 27 root admin 512 May 20 2022 [root]
[2.5.0-RELEASE][root@firewall.dassmbc.com]: sudo find /etc -name "*firewall*" -type f
/etc/rc.firewall
[2.5.0-RELEASE][root@firewall.dassmbc.com]:
```

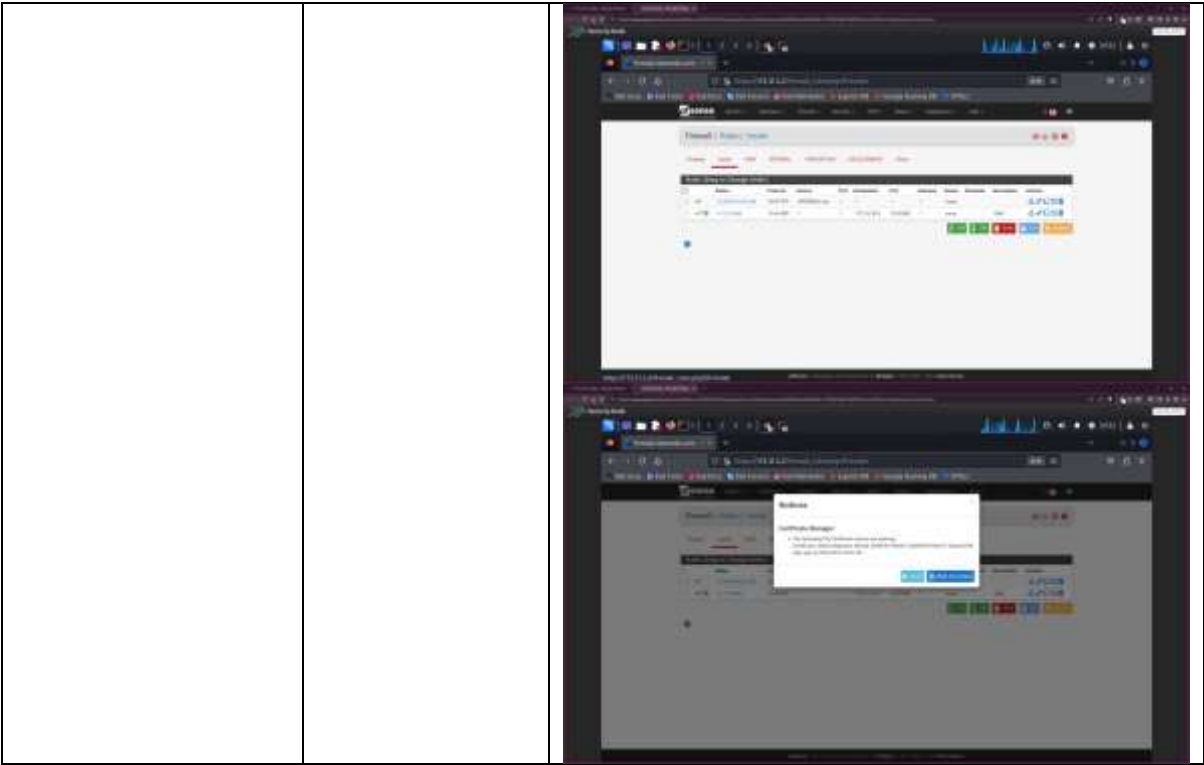
2026-05-07 16:14:25

Executed a series of tcpdump and nmap commands against all three subnets and the DASWebs Inc. network to gather data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project.



The image displays three sequential screenshots of a terminal window, likely a Kali Linux machine, showing the execution of network security tools. The terminal has a dark background with light-colored text. The first screenshot shows the output of a command, possibly a scan or a list of IP addresses. The second screenshot shows a list of IP addresses, some of which are highlighted in red, indicating a specific set of results or errors. The third screenshot shows a list of IP addresses, some of which are highlighted in red, indicating a specific set of results or errors. The terminal window is titled 'Security Dash' and has a menu bar with 'File', 'Actions', 'Edit', and 'View'. The status bar at the bottom shows the current directory as '/root/.ssh' and the file as 'ssh-keygen'. The terminal output includes various network-related commands and their results, such as IP addresses, port numbers, and connection status.

		
2026-05-07 18:23:19	Accessed the Firewall Web UI and gathered additional data for the security assessment required for the CNG 2059: Enterprise Security - Capstone Project.	



Appendix C: Link to OneDrive Folder Containing Scanning Scripts and Scanning Data/Output

[REDACTED]